HARDENING DO LINUX: SUPERFÍCIE DE ATAQUE

Kernel do dia anterior, nenhum CVE aberto, nenhum dia zero — e a máquina foi invadida assim mesmo. O que havia era um banco subido para um teste em janeiro, escutando em `0.0.0.0` com a senha da documentação. ***Ninguém quebrou nada: entraram pela porta que ninguém lembrava de ter deixado aberta.***

085
GUIAS LINUX

AS CINCO CAMADAS — E O COMANDO QUE MEDE CADA UMA

REDE — portas em escuta
quem alcança a máquina sem credencial nenhuma
`ss -tulpn`

SERVIÇOS — daemons ativos
cada um é código rodando e uma configuração a errar
`systemctl list-units --state=running`

CONTAS — shell utilizável, chaves, sudo
quem já está dentro, e até onde consegue ir
`getent passwd`
`cat /etc/sudoers.d/*`

BINÁRIOS PRIVILEGIADOS — SUID, SGID, capabilities
o caminho de usuário local até root
`find / -perm -4000`
`getcap -r /`

KERNEL — módulos, `/proc`, `/sys`, syscalls
a última fronteira; falha aqui derruba tudo acima
`lsmod`
`sysctl -a`

Cada camada só é alcançável depois da anterior — reduzir a de cima vale mais: serviço que não roda não tem CVE que importe, nem patch, nem perfil a escrever. E a diferença que decidiu o caso da abertura: `127.0.0.1:5432` e `0.0.0.0:5432` é o mesmo banco, o mesmo firewall, duas superfícies opostas — **e é opção do serviço, não do firewall**.

CINCO PRINCÍPIOS QUE SUBSTITUEM QUALQUER LISTA DE RECEITAS

MENOR PRIVILÉGIO
Cada processo recebe só o que precisa. Não é desconfiar de gente — é limitar o estrago. `nginx` como `www-data` ou como `root` servem a mesma página; a diferença aparece no dia em que ele é explorado.

DEFESA EM PROFUNDIDADE
A pergunta útil não é "esta medida impede o ataque?", e sim **"QUANDO ELA FALHAR, O QUE AINDA ESTÁ DE PÉ?"** — camadas independentes, nunca alternativas entre si.

FALHAR FECHADO
Diante de erro ou ambiguidade, negue: a política `drop`, a regra de `sudo` que lista o que *pode*, o serviço que recusa configuração inválida.

REDUZIR ANTES DE PROTEGER
Software não instalado não precisa ser configurado, atualizado, monitorado nem confinado. Antes de escrever um perfil, pergunte se o serviço precisa existir — a resposta é "não" com frequência surpreendente.

AUDITABILIDADE
Controle que não deixa registro é controle que você não sabe se funciona — e cuja falha só se descobre quando alguém avisa de fora.

O PADRÃO DE FÁBRICA NÃO É O PADRÃO SEGURO
Distribuições otimizam para "funciona na primeira tentativa", não para "resiste a um adversário". É uma escolha legítima delas e um problema seu.

MEDIR, ENDURECER — E PAGAR O PREÇO COM CONSCIÊNCIA

```
kali@kali: ~
# 1. o retrato ANTES — sem medição, hardening é fé
$ sudo ss -tulpn | grep -v '127.0.0.1\|::1'
tcp LISTEN 0 128 0.0.0.0:5432 (("postgres"...
#    ^ o esquecido de janeiro, exposto à rede inteira
$ systemctl list-unit-files --state=enabled
$ sudo find / -xdev -perm -4000 -type f | sort
# 2. desligar é sempre melhor do que configurar
$ sudo systemctl disable --now cups avahi-daemon
$ sudo systemctl mask bluetooth   # nem por dep.
# 3. kernel — /etc/sysctl.d/99-hardening.conf
kernel.kptr_restrict = 2     kernel.dmesg_restrict = 1
kernel.yama.ptrace_scope = 1 fs.suid_dumpable = 0
$ sudo sysctl --system
# 4. SSH: validar ANTES de recarregar. Sempre.
$ sudo sshd -t && sudo systemctl reload ssh
$ sudo lynis audit system --quick # o placar
```

MEDIDA	O QUE ELA COBRA
`PasswordAuthentication no`	perder a chave privada é perder o acesso
política `drop` no firewall	cada serviço novo exige regra explícita
`noexec` em `/tmp`	instaladores que usam `/tmp` param
`ptrace_scope = 1`	`gdb` e `strace` passam a exigir `sudo`
confinamento estrito	perfil mal ajustado quebra o serviço de forma opaca

Hardening genérico não existe — só para uma máquina com propósito declarado. Ignorar o custo produz o servidor "seguro" que ninguém administra e que acumula gambiarras que anulam tudo.

`sudo sshd -t` **antes de todo** `reload`**, sem exceção** — erro de sintaxe faz o serviço recusar-se a subir, e numa máquina remota isso é perder o acesso em definitivo. **Mantenha a sessão aberta**, abra uma **segunda** para testar, e só feche a primeira quando a segunda funcionar. E `PasswordAuthentication no` sem chave pública instalada **e testada** tranca você para fora na hora.

RESUMO RÁPIDO

- ✓ **A maioria das invasões explora configuração, não vulnerabilidade:** o serviço esquecido em `0.0.0.0` com senha padrão, não o dia zero.
- ✓ **Superfície de ataque é lista finita e enumerável** — rede, serviços, contas, binários privilegiados, kernel — e cada camada tem seu comando.
- ✓ **Fechar a camada de cima vale mais que corrigir tudo abaixo.** Trabalhe do `ss -tulpn` para baixo.
- ✓ **Cinco princípios decidem o que a lista não previu:** menor privilégio, defesa em profundidade, falhar fechado, reduzir antes de proteger, auditabilidade.
- ✓ **Atualizar é a medida de maior retorno** (no Kali, `full-upgrade`). E guarde o "antes": relatório honesto é inventário inicial, final e o `diff`.

NO KALI

O Kali é deliberadamente o oposto de um sistema endurecido, e por bom motivo: ele hospeda ferramentas feitas para gerar tráfego incomum, abrir sockets crus, injetar pacotes e carregar módulos — firewall restritivo, confinamento estrito e `ptrace_scope` alto atrapalhariam isso. Endurecer aqui é **decisão sua, consciente e reversível. Mas ele não é o descuidado que a fama sugere:** desde 2020 usa o usuário não privilegiado `kali` em vez de `root`, e **nenhum serviço de rede sobe habilitado** — `ssh`, `postgresql` e `apache2` vêm desativados, e um `ss -tulpn` novo sai quase vazio. O risco real é o `systemctl enable ssh` que você deu num laboratório há três meses e nunca desfez. `kali-tweaks` **centraliza as decisões:** a seção *Hardening* configura o SSH deste capítulo e inclui *aceitar algoritmos legados* — as duas direções a um menu de distância. **VM clonada herda a chave de host do SSH**, e máquinas com a mesma identidade anulam a checagem de *fingerprint*: `sudo rm /etc/ssh/ssh_host_*` e `dpkg-reconfigure openssh-server`. **Fechar o ciclo:** `nmap -sV -p- 127.0.0.1` e uma varredura de outra VM sua mostram a superfície **como um atacante a vê** — a máquina que você endureceu é o único alvo cuja autorização é indiscutível; contra outro é crime (Lei 12.737/2012). **RHEL** já parte de `firewalld` ativo e SELinux *enforcing*, e troca o `lynis` pelo **OpenSCAP**.